

Marco integrativo GQM + PRAGMATIC para indicadores COBIT de ciberseguridad

Versión 1.0 – Aplicable a indicadores nacionales inspirados en COBIT 2019 (España, enfoque comparativo internacional).[web:18][web:21][web:24]

1. Introducción: de los objetivos país al log de eventos

El propósito de este marco es asegurar que **cada indicador de ciberseguridad** propuesto en el informe COBIT tenga:

- Un Goal claro (objetivo nacional o estratégico).
- Una o varias Questions operativas que explican qué queremos saber.
- Una o varias Metrics bien definidas y evaluadas con los nueve criterios PRAGMATIC: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable.[web:53][web:57][web:61]

Así se consigue la trazabilidad completa: desde la **estrategia país** hasta el **dato técnico** extraído de un SIEM, un inventario de activos o un sistema de ticketing.

2. Recordatorio de los enfoques GQM y PRAGMATIC

2.1. GQM – Goal, Question, Metric

Según la metodología GQM, se parte de un **Goal** (meta) bien definido, se derivan **Questions** (preguntas) que caracterizan ese objetivo y, finalmente, se definen **Metrics** que permiten responder a las preguntas.[web:53][web:57][web:60][web:63]

En nuestro contexto:

- Goal: objetivo nacional de ciberseguridad alineado con COBIT (p.ej., “Optimizar el riesgo de ciberseguridad a nivel país”).
- Questions: qué necesitamos saber para saber si el objetivo avanza (p.ej., “¿Con qué frecuencia revisa el gobierno los indicadores de riesgo?”).
- Metrics: datos cuantificables (p.ej., “nº de reuniones anuales del Consejo con agenda de ciberseguridad”).

2.2. PRAGMATIC – Nueve criterios de calidad de métricas

El enfoque PRAGMATIC propone puntuar las métricas según nueve criterios,[web:61][web:58][web:59][web:64]

- P – Predictivo: ayuda a anticipar futuros estados o riesgos.
- R – Relevante: guarda relación directa con los objetivos de decisión.
- A – Accionable: conduce claramente a posibles acciones de mejora o decisión.
- G – Genuino: mide realmente lo que dice medir, sin trucos semánticos.
- M – Significativo (Meaningful): es comprensible y significativo para los decisores.
- A – Preciso (Accurate): suficientemente exacto y fiable para el uso previsto.
- T – Oportuno (Timely): disponible con la frecuencia y rapidez necesarias.
- I – Independiente: difícil de manipular, poco sujeto a intereses de parte.
- C – Rentable (Cheap): coste de recopilación razonable frente al valor.

Cada métrica se puede puntuar de 0 a 10 en cada criterio, obteniendo un **metametric score** PRAGMATIC.[web:61][web:64]

3. Dominios COBIT y objetivos nacionales (nivel Goal)

Retomando el informe de indicadores COBIT, se establecen los siguientes **Goals** de alto nivel:

1.

G1 – Gobierno y riesgo (EDM03)

“Asegurar que el gobierno nacional y los órganos de gobierno de las organizaciones clave optimizan el riesgo de ciberseguridad de forma informada y periódica.”[web:34][web:27]

2.

G2 – Gestión del riesgo de TI (APO12)

“Conseguir que las organizaciones gestionen el riesgo de TI/ciberseguridad de forma sistemática y alineada con el riesgo corporativo.”[web:14][web:24]

3.

G3 – Seguridad gestionada (APO13)

“Implantar y mantener sistemas de gestión de seguridad de la información (SGSI) efectivos y alineados con estándares reconocidos.”[web:24][web:44]

4.

G4 – Cambios de TI seguros (BAI06)

“Garantizar que los cambios de TI se realizan con un tratamiento adecuado del riesgo de ciberseguridad y sin generar incidentes evitables.”[web:21][web:24]

5.

G5 – Servicios de seguridad eficaces (DSS05)

“Asegurar que las organizaciones disponen de servicios de seguridad (SOC, detección, respuesta, gestión de vulnerabilidades) eficaces y eficientes.”[web:17][web:21][web:46]

6.

G6 – Continuidad y resiliencia (DSS04)

“Mejorar la capacidad de las organizaciones para resistir y recuperarse de ciberincidentes que afecten a la continuidad del negocio.”[web:27][web:22]

7.

G7 – Monitorización, auditoría y mejora (MEA01-03)

“Fomentar una cultura de monitorización continua, auditoría y mejora basada en datos de ciberseguridad.”[web:17][web:34]

G1 – Gobierno y riesgo (EDM03)

“Asegurar que el gobierno nacional y los órganos de gobierno de las organizaciones clave **optimizan el riesgo de ciberseguridad** de forma informada y periódica.”[web:34][web:27]

G2 – Gestión del riesgo de TI (APO12)

“Conseguir que las organizaciones gestionen el **riesgo de TI/ciberseguridad** de forma sistemática y alineada con el riesgo corporativo.”[web:14][web:24]

G3 – Seguridad gestionada (APO13)

“Implantar y mantener sistemas de gestión de seguridad de la información (SGSI) efectivos y alineados con estándares reconocidos.”[web:24][web:44]

G4 – Cambios de TI seguros (BAI06)

“Garantizar que los cambios de TI se realizan con un tratamiento adecuado del riesgo de ciberseguridad y sin generar incidentes evitables.”[web:21][web:24]

G5 – Servicios de seguridad eficaces (DSS05)

“Asegurar que las organizaciones disponen de servicios de seguridad (SOC, detección, respuesta, gestión de vulnerabilidades) eficaces y eficientes.”[web:17][web:21][web:46]

G6 – Continuidad y resiliencia (DSS04)

“Mejorar la capacidad de las organizaciones para resistir y recuperarse de ciberincidentes que afecten a la continuidad del negocio.”[web:27][web:22]

G7 – Monitorización, auditoría y mejora (MEA01-03)

“Fomentar una cultura de monitorización continua, auditoría y mejora basada en datos de ciberseguridad.”[web:17][web:34]

Cada uno de estos Goals se descompone en Questions específicas y Metrics asociadas.

4. Ejemplo de aplicación GQM + PRAGMATIC por indicador

A continuación se presenta la estructura GQM+PRAGMATIC para los indicadores clave propuestos en el informe COBIT.

Nota: los scores PRAGMATIC son orientativos (escala 0-10) y pueden ajustarse según contexto nacional o sectorial.[web:61][web:64]

4.1. G1 – Gobierno y optimización del riesgo (EDM03)

4.1.1. Indicador: Frecuencia de revisión de ciberseguridad en el órgano de gobierno

- Goal (G1): Optimizar el riesgo de ciberseguridad a través de una supervisión efectiva por parte del órgano de gobierno.
- Question:
- Q1.1: ¿Con qué frecuencia el órgano de gobierno revisa la información estructurada de ciberseguridad (riesgos, incidentes, planes)?
- Metric M1.1: N° de reuniones al año del órgano de gobierno donde la ciberseguridad figura explícitamente en la agenda, medido a nivel organización; agregable a nivel país como media o distribución.

PRAGMATIC (M1.1) – puntuación sugerida:

Criterio	Descripción	Score (0-10)
Predictivo	Frecuencia baja anticipa posible falta de respuesta estratégica futura.	7
Relevante	Directamente alineado con el objetivo de gobierno de riesgo.	9
Accionable	Si es bajo, se puede aumentar la frecuencia o calidad de las sesiones.	8
Genuino	Mide realmente la atención del órgano de gobierno (aunque no la calidad).	7
Significativo	Fácil de entender por dirección y reguladores.	9
Preciso	Puede medirse con actas o agendas formales.	8
Oportuno	Se actualiza anualmente con facilidad.	8
Independiente	Difícil de manipular si se revisan actas oficiales.	7
Rentable	Muy barato de obtener.	9

4.1.2. Indicador: Existencia de informes de ciberseguridad con objetivos y métricas

- Question:
- Q1.2: ¿Recibe el órgano de gobierno informes de ciberseguridad con objetivos, métricas y brechas definidas?
- Metric M1.2: Nivel de formalización del informe codificado (0: inexistente; 1: puntual; 2: anual; 3: periódico estructurado; 4: cuadro de mando integrado).

PRAGMATIC (M1.2):

- Predictivo: 8 (sin informes formales, es más probable una gestión reactiva futura).
- Relevante: 9.
- Accionable: 8 (se puede formalizar y mejorar el informe).
- Genuino: 7 (mide existencia y formalización, no calidad del contenido).
- Significativo: 9.
- Preciso: 7 (algunas respuestas pueden ser algo subjetivas).
- Oportuno: 8.
- Independiente: 6 (puede maquillarse, requiere contraste documental).
- Rentable: 9.

4.2. G2 – Gestión del riesgo de TI (APO12)

4.2.1. Indicador: Proceso formal de gestión de riesgos de TI

- Question:
- Q2.1: ¿Existe y se aplica un proceso formal de gestión de riesgos de TI/ciberseguridad?
- Metric M2.1: Grado de formalización del proceso (0: inexistente; 1: prácticas dispersas; 2: proceso definido pero irregular; 3: proceso sistemático; 4: integrado con riesgo corporativo).

PRAGMATIC (M2.1) – sugerido:

Criterio	Score
Predictivo	8
Relevante	9
Accionable	9
Genuino	7
Significativo	9
Preciso	7
Oportuno	8
Independiente	6
Rentable	8

4.2.2. Indicador: Cobertura de activos críticos con análisis de riesgos

- Question:
- Q2.2: ¿Qué porcentaje de activos críticos cuenta con análisis de riesgos actualizado en los últimos 12 meses?
- Metric M2.2: Porcentaje de activos críticos con análisis de riesgos vigente (rangos o valor numérico).

PRAGMATIC (M2.2):

- Predictivo: 8 (baja cobertura anticipa problemas futuros).
- Relevante: 9.
- Accionable: 8 (posible plan de ampliación de cobertura).
- Genuino: 8 (si los inventarios están bien).
- Significativo: 8.
- Preciso: 7 (depende de calidad de inventario).
- Oportuno: 7 (revisión anual/semestral).
- Independiente: 6 (riesgo de sobreestimar cobertura).
- Rentable: 7 (requiere inventario y seguimiento).

4.3. G3 – Seguridad gestionada / SGSI (APO13)

4.3.1. Indicador: Existencia y madurez de SGSI

- Question:
- Q3.1: ¿Existe un SGSI formal y operativo? ¿En qué grado?
- Metric M3.1: Nivel de madurez del SGSI (0–4) en función de la escala de opciones de encuesta.

PRAGMATIC (M3.1):

Criterio	Score
Predictivo	8
Relevante	9
Accionable	8
Genuino	7
Significativo	9
Preciso	7
Oportuno	8
Independiente	6
Rentable	7

4.3.2. Indicador: Alineamiento / certificación ISO 27001

- Metric M3.2: Nivel de alineamiento/certificación (0: ninguno; 1: referencia informal; 2: alineado; 3: certificado parcial; 4: certificado amplio).

PRAGMATIC (M3.2):

- Predictivo: 7.
- Relevante: 8.
- Accionable: 7.
- Genuino: 8 (certificación es evidencia contundente).
- Significativo: 8.
- Preciso: 9 (o está certificada, o no).
- Oportuno: 7 (ciclos de certificación).
- Independiente: 8 (certificación externa).
- Rentable: 6 (información fácil, pero certificarse no es “barato”).

4.3.3. Indicador: Porcentaje del presupuesto TI dedicado a seguridad

- Metric M3.3: % del presupuesto TI dedicado a seguridad y gobierno de la información.

PRAGMATIC (M3.3):

- Predictivo: 7 (más inversión no siempre implica más seguridad, pero ayuda).
- Relevante: 7.
- Accionable: 8 (sirve para justificar aumentos o reasignaciones).
- Genuino: 6 (puede esconder gastos en otras partidas).
- Significativo: 8.
- Preciso: 7 (depende de clasificación contable).
- Oportuno: 7 (ciclos presupuestarios).
- Independiente: 6.
- Rentable: 8 (dato contable disponible).

4.4. G4 – Cambios de TI seguros (BAI06)

4.4.1. Indicador: % de cambios críticos con evaluación de seguridad

- Question:
- Q4.1: ¿Qué proporción de cambios en sistemas críticos incluye evaluación formal de impacto en seguridad?
- Metric M4.1: % de cambios críticos con evaluación de seguridad previa.

PRAGMATIC (M4.1):

Criterio	Score
Predictivo	8
Relevante	9
Accionable	9
Genuino	7
Significativo	8
Preciso	7
Oportuno	7
Independiente	6
Rentable	7

4.4.2. Indicador: Incidentes de seguridad debidos a cambios

- Metric M4.2: % de incidentes de seguridad atribuibles a cambios mal gestionados.

PRAGMATIC (M4.2):

- Predictivo: 8 (si se mantiene alta, mal asunto).
- Relevante: 8.
- Accionable: 8 (dirige mejoras al proceso de cambios).
- Genuino: 6 (análisis de causa raíz no siempre riguroso).
- Significativo: 8.
- Preciso: 6.
- Oportuno: 7.
- Independiente: 6.
- Rentable: 6.

4.5. G5 – Servicios de seguridad eficaces (DSS05)

4.5.1. Indicador: Nivel de capacidades SOC

- Metric M5.1: Nivel de madurez de capacidades de monitorización y SOC (escala ordinal 0–4 basada en opciones de encuesta).

PRAGMATIC (M5.1):

Criterio	Score
Predictivo	8
Relevante	9
Accionable	8
Genuino	7
Significativo	9
Preciso	7
Oportuno	7
Independiente	6
Rentable	7

4.5.2. Indicador: MTTD y MTTR de incidentes

- Metrics M5.2: MTTD medio; MTTR medio para incidentes significativos.[web:46][web:21]

PRAGMATIC (M5.2):

- Predictivo: 9 (tiempos largos anticipan impacto elevado).
- Relevante: 9.
- Accionable: 9 (objetivos claros de mejora).
- Genuino: 8 (si se definen bien los incidentes significativos).
- Significativo: 9.
- Preciso: 7-8.
- Oportuno: 7 (reportes periódicos).
- Independiente: 6-7 (puede haber sesgos de clasificación).
- Rentable: 7.

4.5.3. Indicador: % de vulnerabilidades críticas resueltas en plazo

- Metric M5.3: % de vulnerabilidades críticas resueltas dentro del SLA interno.

PRAGMATIC (M5.3):

Criterio	Score
Predictivo	8
Relevante	9
Accionable	9
Genuino	8
Significativo	8
Preciso	7
Oportuno	7
Independiente	6
Rentable	7

4.6. G6 – Continuidad y resiliencia (DSS04)

4.6.1. Indicador: BCP/DRP probados

- Metric M6.1: Estado y frecuencia de pruebas de BCP/DRP (escala ordinal 0–4).

PRAGMATIC (M6.1):

- Predictivo: 8.
- Relevante: 9.
- Accionable: 8.
- Genuino: 7.
- Significativo: 9.
- Preciso: 7.
- Oportuno: 7.
- Independiente: 6.
- Rentable: 7.

4.6.2. Indicador: Simulacros de ciber crisis con dirección

- Metric M6.2: Frecuencia de simulacros de ciber crisis con participación de alta dirección.

PRAGMATIC (M6.2):

- Predictivo: 8 (organizaciones que ensayan responden mejor).
- Relevante: 8.
- Accionable: 8.
- Genuino: 7.
- Significativo: 8.
- Preciso: 8 (agenda y actas).
- Oportuno: 7.
- Independiente: 7.
- Rentable: 6.

4.7. G7 – Monitorización, auditoría y mejora (MEA01-03)

4.7.1. Indicador: Cuadro de mando de ciberseguridad

- Metric M7.1: Nivel de formalización del cuadro de mando de ciberseguridad (0–4).

PRAGMATIC (M7.1):

Criterio	Score
Predictivo	8
Relevante	9
Accionable	9
Genuino	7
Significativo	9
Preciso	7
Oportuno	8
Independiente	6
Rentable	8

4.7.2. Indicador: Auditorías y acciones correctivas

- Metric M7.2: Frecuencia de auditorías de seguridad (ordinal).
- Metric M7.3: % de acciones correctivas cerradas en plazo.

PRAGMATIC (M7.2 + M7.3):

- Predictivo: 8.
- Relevante: 8.
- Accionable: 8.
- Genuino: 7.
- Significativo: 8.
- Preciso: 7.
- Oportuno: 7.
- Independiente: 6-7.
- Rentable: 7.

5. Uso del marco GQM + PRAGMATIC a nivel nacional

8. Definir objetivos nacionales (Goals) alineados con estrategia de ciberseguridad y marcos (COBIT, NIS2, ENS, etc.).[web:18][web:24][web:43]
9. Derivar preguntas (Questions) que permitan caracterizar el estado de cada objetivo.
10. Seleccionar métricas (Metrics) factibles a partir de datos que las organizaciones puedan aportar (encuestas, sistemas, registros).
11. Puntuar PRAGMATIC cada métrica para priorizar las más útiles y descartar las decorativas.
12. Construir índices agregados (IGM, subíndices por dominio) sabiendo exactamente qué se está midiendo y qué nivel de calidad tiene cada métrica.

6. Consideraciones finales

- El marco no es estático: las métricas pueden evolucionar según cambien amenazas, normativas y capacidades de medición.
- El análisis PRAGMATIC invita a revisar periódicamente si una métrica sigue siendo digna de seguir viva.
- La combinación GQM + PRAGMATIC actúa como vacuna contra el síndrome de “dashboard bonito pero inútil”.

Fin del documento.